

R&D · INTERNSHIP PROTOTYPE



SECWEAVE

Nền tảng hỗ trợ kiểm thử bảo mật liên tục bằng AI

"Từ signal đến finding có evidence, remediation và fix verification."

VERSION

1.0

TIMELINE

2 tháng

TEAM

2 thành viên

DOMAIN

AI Agent · Security

Người thực hiện: Vũ Văn Nam · Nguyễn Duy Phúc

Manager: Nguyễn An Hưng · Mentor: [Chờ chỉ định]

01

Thông tin tài liệu

Trang này tóm tắt các thông tin định danh cơ bản của đề xuất, bao gồm phạm vi, nhân sự, thời gian và trạng thái phê duyệt.

Thuộc tính	Nội dung
Tên dự án	SecWeave
Tên kỹ thuật của core	System Security Context Engine
Trạng thái	Đề xuất — trước khi triển khai
Loại dự án	Dự án thực tập / R&D Prototype
Thời gian dự kiến	2 tháng (8 tuần)
Nhân sự	2 thành viên
Kỹ năng chính	AI Agent và Security
Ngày trình bày	—
Người thực hiện 1	Vũ Văn Nam
Người thực hiện 2	Nguyễn Duy Phúc
Manager	Nguyễn An Hưng
Mentor đề xuất	[Chờ chỉ định]
Phiên bản tài liệu	1.0

Chỉ số dự án

2	2	~\$40	8
THÁNG · TIMELINE	THÀNH VIÊN	NGÂN SÁCH API	TUẦN TRIỂN KHAI

i **Tài liệu này** mô tả đề xuất kỹ thuật và quản trị cho MVP (vertical slice) của SecWeave. Tầm nhìn tổng thể của dự án còn bao gồm nhiều phase mở rộng (multi-service, organization learning, CI/CD integration) sẽ được đề xuất trong các giai đoạn tiếp theo.

Mục lục

01	Thông tin tài liệu	0
02	Tóm tắt điều hành	0
03	Bối cảnh & Vấn đề	0
04	Phạm vi dự án	0
05	Mục tiêu	0
06	Kiến trúc hệ thống	0
07	Mô hình dữ liệu & State Machine	0
08	Discovery Lanes & Model Routing	0
09	Kế hoạch triển khai 8 tuần	0
10	Ngân sách & Nhân sự	0
11	Rủi ro & Giảm thiểu	0
12	Tiêu chí đánh giá	0

02

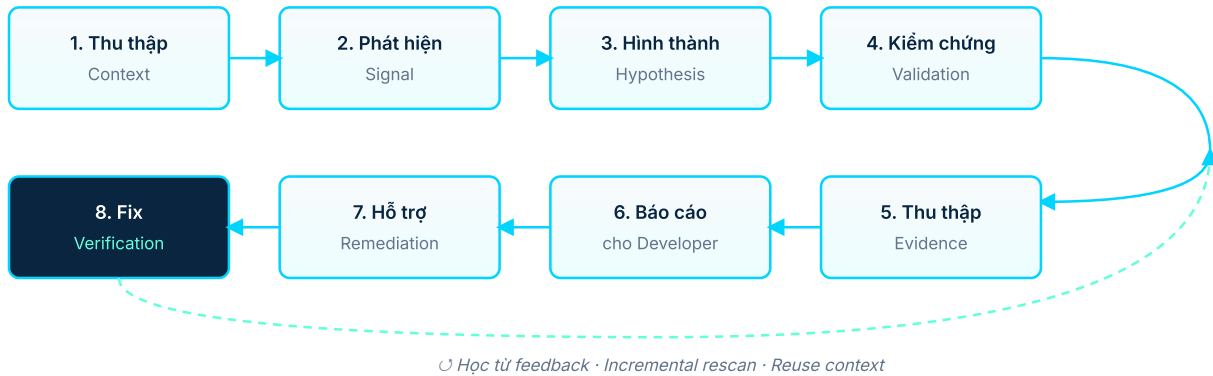
Tóm tắt điều hành

SecWeave là dự án xây dựng một nền tảng hỗ trợ thực hiện quy trình kiểm thử bảo mật ứng dụng theo hướng *liên tục, có trạng thái và có bằng chứng*. Trong giai đoạn thực tập 2 tháng, nhóm sẽ xây dựng một MVP theo dạng **vertical slice** — nhỏ về phạm vi nhưng thể hiện vòng đời hoàn chỉnh từ phân tích đến fix verification.

Hệ thống kết hợp

-  **AI Agent** điều phối toàn bộ quy trình phân tích và ra quyết định
-  **Phân tích source code (SAST)** — Semgrep, AST, symbol graph
-  **SCA & kiểm tra dependency/CVE** — Trivy, SBOM
-  **DAST & runtime testing** khi được cấp phép
-  **Persistent Security Context** — lưu trữ context giữa các lần chạy
-  **Independent Validation** — agent thứ hai kiểm chứng độc lập
-  **Developer Feedback Loop** — học từ phản hồi của developer
-  **Remediation & Fix Verification** — hỗ trợ sửa và kiểm tra bản sửa
-  **Incremental Analysis** — chỉ phân tích lại phần thay đổi

Quy trình khép kín (end-to-end)



Vòng đời SecWeave: từ Context đến Fix Verification, có phản hồi và học liên tục.

✓ **Điểm khác biệt:** SecWeave không chỉ sinh cảnh báo. Hệ thống duy trì **System Security Context** giữa các lần chạy, kiểm chứng độc lập, yêu cầu **evidence** trước khi báo finding, và học từ developer feedback.

03

Bối cảnh & Vấn đề

Các hệ thống hiện đại ngày càng phức tạp — nhiều service, nhiều repository, nhiều dependency trực tiếp và gián tiếp, authentication/authorization dùng chung. Điều này đặt ra nhiều thách thức mà các công cụ security truyền thống chưa giải quyết trọn vẹn.

3.1. Pain points hiện tại

#	Pain point	Tác động
1	Dependency scanner phát hiện nhiều CVE nhưng chưa xác định CVE nào thực sự ảnh hưởng đến hệ thống	Nhiều false positive, tốn thời gian triage
2	SAST sinh nhiều cảnh báo nhưng thiếu <i>business context</i>	Developer bỏ qua, missed real vulnerabilities
3	Một lỗi hổng có thể liên quan đến nhiều file, service hoặc repository	Khó truy vết root cause
4	Developer khó xử lý nếu báo cáo thiếu cách tái hiện (repro), impact và remediation cụ thể	Fix chậm, có thể fix sai
5	Mỗi lần scan phải khám phá lại kiến trúc và security control	Lãng phí tài nguyên tính toán
6	Full scan lặp lại tốn thời gian, token và chi phí	Chi phí AI/tool tăng cao
7	Pentest thủ công thường xuyên cần nhiều nhân lực security	Không scale được theo tốc độ dev
8	Kết quả từ các công cụ khác nhau chưa được kết nối thành một security context thống nhất	Fragmented view, khó ra quyết định

⚠ **Hệ quả:** Nhiều tổ chức có đủ scanner nhưng vẫn thiếu một bức tranh bảo mật toàn diện, đáng tin cậy và có thể hành động. Developer đôi khi mất niềm tin vào cảnh báo tự động vì tỉ lệ noise cao.

3.2. Giả thuyết của dự án

Nếu hệ thống có thể duy trì một **System Security Context** bên ngoài model, đồng thời lưu *provenance*, *evidence*, *coverage* và *developer feedback*, thì các lần phân tích sau có thể:

- Cần ít công sức khám phá lại hơn
- Cung cấp đúng context hơn cho AI agent
- Giảm số signal không hữu ích đến tay developer
- Tăng khả năng tái hiện finding
- Cải thiện chất lượng remediation
- Chỉ phân tích lại phần thay đổi hoặc bị ảnh hưởng
- Giảm thời gian và chi phí incremental scan so với full scan

Đây là giả thuyết cần được **kiểm chứng bằng benchmark và số liệu thực tế** trong quá trình triển khai.

04

Phạm vi dự án

MVP hai tháng là **vertical slice** đầu tiên: đủ nhỏ để hoàn thành trong thời gian giới hạn, đủ đầy đủ để chứng minh vòng đời end-to-end. Các tính năng nâng cao được đưa vào roadmap phase tiếp theo.

✅ In-Scope (MVP 2 tháng)

- Chạy trên **1 repo open-source** làm target chính
- Hỗ trợ **1 stack web** (Python hoặc Node.js)
- Tích hợp **Semgrep (SAST) + Trivy (SCA)**
- Persistent state với **SQLite**
- Phân tách rõ *discovery* và *validation*
- Báo cáo finding sẵn sàng cho developer với **evidence**
- Tích hợp Claude Code / Codex qua **Agent Skill / CLI / MCP**
- **Incremental analysis** (chỉ phân tích diff)
- Developer feedback loop cơ bản
- Đo lường token, cost, latency, cache hit

❌ Out-of-Scope

- Chưa triển khai **production deployment**
- Không tự động merge code không qua human review
- Không thay thế hoàn toàn pentester / security engineer
- Không cam kết loại bỏ 100% false positive
- Không hỗ trợ mobile / binary / firmware
- Không tích hợp CI/CD production pipeline
- Không cung cấp SLA operational
- Không hỗ trợ nhiều stack cùng lúc
- Không có cross-organization learning
- Không active testing trên production

4.3. Những điều dự án KHÔNG tuyên bố



SecWeave **không** tuyên bố:

- Loại bỏ hoàn toàn false positive
- Chứng minh một hệ thống hoàn toàn không có lỗ hổng
- Tự động khai thác hệ thống ngoài phạm vi được phép
- Có thể hiểu chính xác mọi business logic ngay từ lần chạy đầu tiên
- Mọi CVE được phát hiện đều có thể khai thác

Kết luận đúng của một lần scan phải là: "Không có finding được xác nhận trong phạm vi và coverage đã thực hiện" — không phải "Hệ thống không có vulnerability".

05

Mục tiêu

5.1. Mục tiêu tổng thể

🎯 **Xây dựng một security harness** *model-agnostic, persistent, evidence-first và incremental*, có khả năng hỗ trợ phân tích source code, dependency, runtime behavior và quan hệ giữa nhiều thành phần hệ thống.

5.2. Mục tiêu chức năng

01 Agent integration Tích hợp với Claude Code / Codex qua Agent Skill / CLI / MCP	02 Model-agnostic Không phụ thuộc một model hoặc provider duy nhất	03 Hybrid testing Hỗ trợ whitebox, blackbox và hybrid
04 Semantic partition Phân rã hệ thống thành các vùng semantic để agent phân tích	05 Persistent state Lưu context, evidence, coverage giữa các lần chạy	06 Signal vs Finding Phân biệt rõ signal / hypothesis / confirmed finding
07 Independent validator Sử dụng validator độc lập để phản biện finding	08 Developer report Sinh báo cáo để developer có thể tái hiện và sửa lỗi	09 Cost measurement Đo chi phí trên mỗi finding được xác nhận / chấp nhận

5.3. Mục tiêu phi chức năng

Yêu cầu	Mô tả
Resumability	Task có thể tạm dừng và tiếp tục sau khi bị gián đoạn

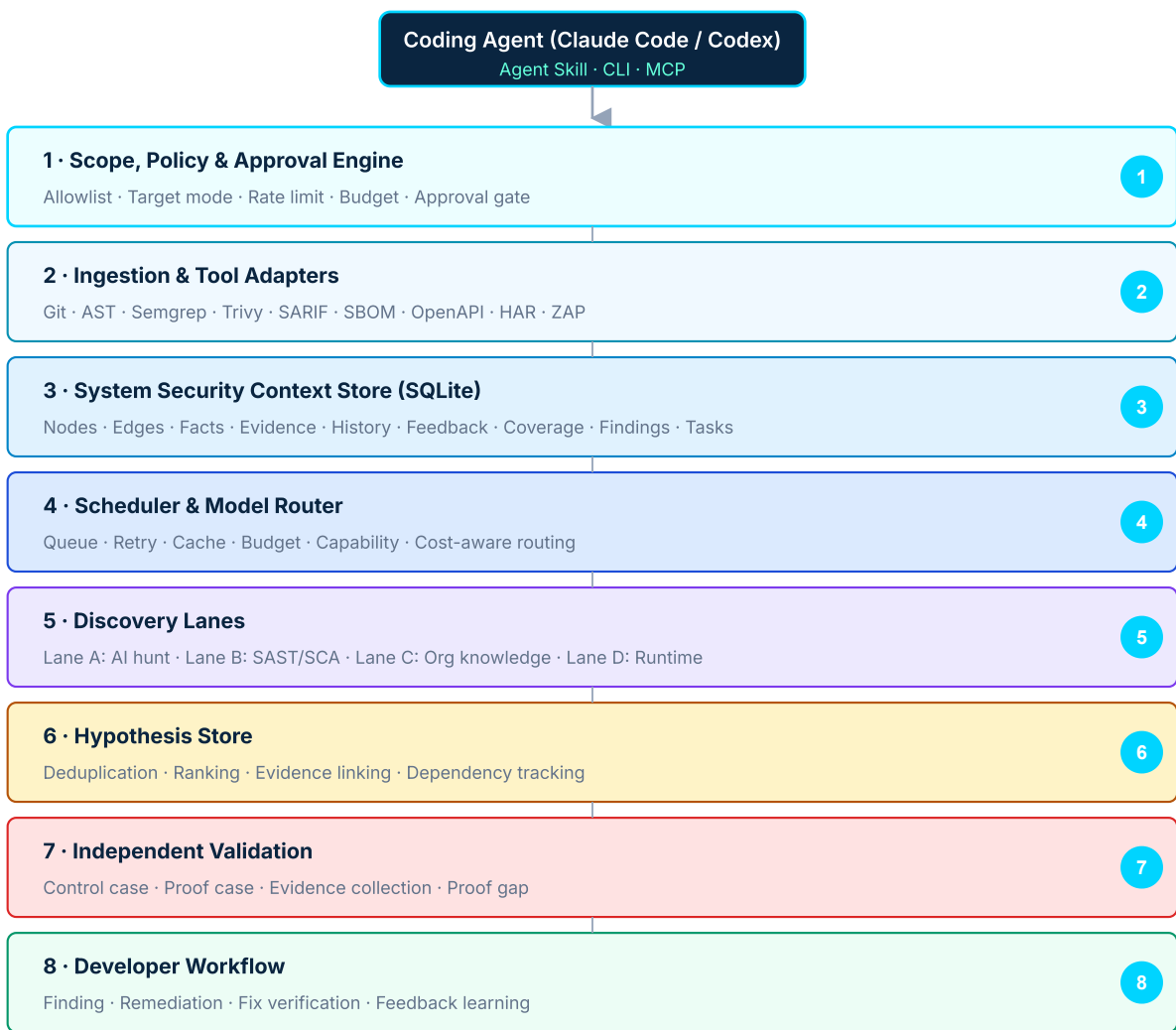
Audit trail	Ghi lại toàn bộ quyết định, thao tác quan trọng và promotion rule
Provenance	Mọi fact / evidence có nguồn gốc, revision, extractor version, confidence
Budget control	Giới hạn token, rate limit, budget theo project và task
Structured output	Output có schema rõ ràng để giảm lỗi tích hợp
Scope enforcement	Không active test ngoài phạm vi được phê duyệt
Extensibility	Có thể mở rộng từ một repository sang nhiều service

06

Kiến trúc hệ thống

6.1. Kiến trúc phân lớp

SecWeave được thiết kế theo 8 lớp, từ điểm vào (agent) đến developer workflow. Mỗi lớp có trách nhiệm rõ ràng và có thể thay thế/nâng cấp độc lập.



Kiến trúc phân lớp 8 tầng của SecWeave — dữ liệu chảy từ agent xuống developer workflow.

6.2. Chi tiết các module

Scope, Policy & Approval Engine

Kiểm soát phạm vi hoạt động của agent: xác định allowlist target, chế độ testing (primary / related / passive), giới hạn ngân sách và rate. Mọi hành động active testing phải qua approval gate.

allowlist

budget

policy

approval

Tool Adapters

Chuẩn hoá output từ Semgrep, Trivy, ZAP, SARIF, SBOM về schema chung. Cho phép thay thế/thêm tool mà không thay đổi phần lõi.

Semgrep

Trivy

ZAP

SARIF

SBOM

System Security Context Store

Đồ thị lưu trữ trên SQLite chứa toàn bộ observation, fact, invariant, hypothesis, finding và evidence. Đây là "bộ nhớ dài hạn" của hệ thống, thay thế việc phụ thuộc vào context window của model.

SQLite

Graph

Provenance

Scheduler & Model Router

Điều phối task, quản lý queue/retry/cache và chọn model phù hợp với task theo cost-aware routing (xem chi tiết trong chương Model Routing).

Queue

Retry

Cache

Routing

Discovery Lanes

4 làn phát hiện song song, mỗi làn có tín hiệu và điểm mạnh riêng: AI context-first, tool deterministic, org knowledge, runtime observation. Kết quả được merge vào Hypothesis Store.

AI

SAST

SCA

DAST

Hypothesis Store

Lưu trữ candidate lỗ hổng chưa xác nhận. Có cơ chế xếp hạng theo severity/confidence và khử trùng lặp bằng semantic fingerprint.

[Ranking](#)[Dedup](#)[Fingerprint](#)

Independent Validation

Agent riêng biệt (khác với agent phát hiện) chịu trách nhiệm kiểm chứng hypothesis bằng control case và proof case. Phát hiện không tự xác nhận chính mình.

[Sandbox](#)[Isolation](#)[Proof case](#)

Developer Workflow

Quản lý finding lifecycle, sinh báo cáo có evidence, đề xuất remediation, kiểm tra bản sửa và học từ developer feedback.

[Report](#)[Feedback](#)[Fix verify](#)

07

Mô hình dữ liệu & State Machine

7.1. Các khái niệm cốt lõi

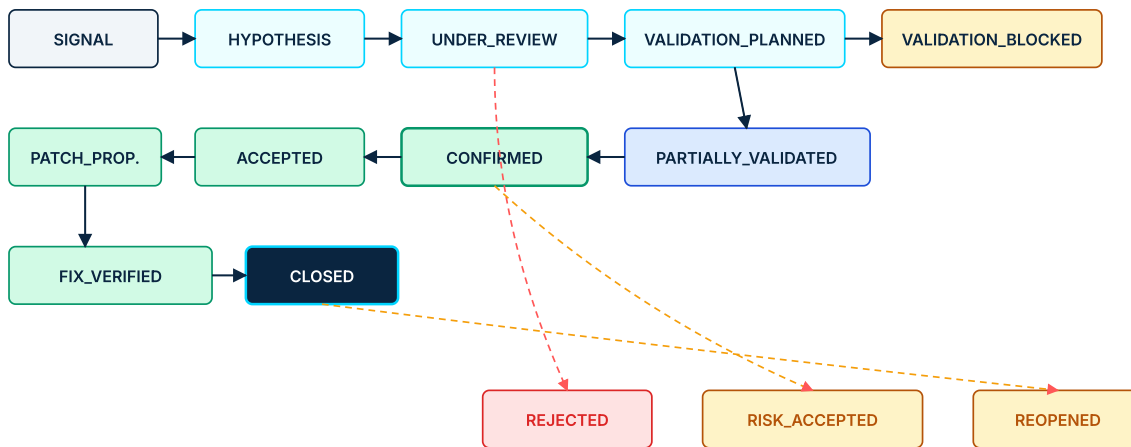
SecWeave tách biệt rõ giữa dữ kiện quan sát được, giả định, tín hiệu ban đầu và finding đã xác nhận. Đây là nền tảng để giảm false positive và tăng tính đáng tin cậy.

Khái niệm	Định nghĩa	Ví dụ
Observation	Một hành vi được quan sát	GET /users/123 trả về HTTP 200
Fact	Dữ kiện có <i>provenance</i> (nguồn gốc rõ ràng)	Route /api/user có middleware auth
Assumption	Điều chưa được xác minh hoặc do người khai báo	Giả định JWT được validate ở gateway
Invariant	Thuộc tính bảo mật phải luôn đúng	Tenant A không được đọc data của tenant B
Signal	Cảnh báo ban đầu từ tool, rule hoặc AI (chưa phải vulnerability)	Semgrep phát hiện SQL injection pattern
Hypothesis	Ứng viên vulnerability chưa được xác nhận	Có thể có IDOR ở endpoint /order/:id
Finding	Hypothesis đã đạt ngưỡng evidence theo policy	IDOR đã được xác nhận, có PoC reproducible
Evidence	Artifact hỗ trợ chứng minh / bác bỏ hypothesis	Source location, HTTP log, screenshot, test result

i Nguyên tắc provenance: mỗi fact phải có origin, evidence reference, source revision, extractor/model version, confidence và created time. Không có provenance thì chỉ được coi là *assumption* hoặc *hypothesis*.

7.2. Finding State Machine

Mỗi finding đi qua state machine sau. Việc phân trạng thái rõ ràng giúp phân biệt cái gì đang chờ, cái gì đã confirmed và cái gì đã được sửa.



CHÚ THÍCH: □ Đang xử lý □ Thành công □ Reject □ Nhánh phụ ■ Kết thúc

Đường liền: dòng chính · Đường đứt: nhánh phụ / trạng thái ngoại lệ

Finding có thể REOPEN khi code, dependency, security control hoặc runtime assumption thay đổi

State machine của Finding — từ SIGNAL đến CLOSED, với các nhánh phụ REJECTED / RISK_ACCEPTED / REOPENED.

08

Discovery Lanes & Model Routing

8.1. Discovery Lanes

Để tránh việc AI bị bias bởi kết quả tool và ngược lại, SecWeave tách phase phát hiện thành 4 làn độc lập chạy song song. Kết quả các lane được merge vào một Hypothesis Store thống nhất.

Lane A • Context-first AI Hunt

Agent tự tìm kiếm dựa trên kiến trúc, threat model và invariants của hệ thống. **Không** đưa toàn bộ tool alerts vào ngay từ đầu để tránh anchoring bias. Phù hợp với các lỗ hổng cần hiểu business logic và data flow.

Threat model

Business logic

Data flow

Lane B • Deterministic Tool Signals

Tín hiệu từ Semgrep, Trivy, ZAP, CodeQL (giai đoạn sau), secret scanning, SBOM. Nhanh, đáng tin cậy về mặt pattern nhưng cần triage để loại bỏ false positive.

Semgrep

Trivy

ZAP

SBOM

Lane C • Organization Knowledge

Học từ lỗi team thường gặp, dismissal reasons, known-unsafe wrapper, known-safe control, previous incidents và developer feedback đã được reviewer phê duyệt.

Historical

Team preferences

Known controls

Lane D · Runtime Observation

Quan sát hành vi thực tế qua HAR, browser/API behavior, logs, traces và authentication role matrix. Cần thiết cho blackbox và runtime validation.

- HAR
- Traces
- Role matrix

8.2. Model Routing — 4 Tier

Không phải task nào cũng cần LLM mạnh. SecWeave chỉ escalate lên tier cao khi tier thấp không đủ, giúp tối ưu chi phí đáng kể.

Tier	Loại model	Chi phí	Use case chính & ví dụ
Tier 0	Deterministic code (không dùng LLM)	Free	Hash/diff · AST · Route extraction · Tool execution · Cache · Deduplication · Scheduling · Scope enforcement
Tier 1	Model chi phí thấp	Rẻ	Fact extraction · Region summary · Source/sink classification · Side-effect identification · Structured output
Tier 2	Model trung bình	Trung bình	Cross-region linking · Authorization reasoning · Constraint transformation · Tool finding triage · Validation planning
Tier 3	Model mạnh	Cao	Cross-system reasoning · Business logic · Contradictory evidence · High-impact hypothesis · Complex validation · Final report review

Nguyên tắc: chỉ escalate lên tier cao khi các tier thấp không đủ. Cache và incremental analysis giúp giảm chi phí đáng kể. Discovery và validation nên dùng model/provider độc lập để giảm correlated error.

09

Kế hoạch triển khai 8 tuần

Kế hoạch được chia thành các block tuần rõ ràng, mỗi tuần có deliverable cụ thể. Sau tuần 4 là **mid-point review**: nếu tiến độ chậm, các tính năng stretch có thể bị cắt bỏ để đảm bảo vertical slice hoàn chỉnh.



Timeline 8 tuần · Mid-point review sau T4 · Final demo tại T8.

TUẦN
01**Baseline & Kiến trúc**

- Chọn & phân tích repository benchmark open-source
- Chạy Semgrep + Trivy + AI-agent baseline để có tham chiếu
- Thiết lập canonical schemas (fact, hypothesis, finding, evidence)
- Chốt threat model, stack MVP, tiêu chí đánh giá
- Setup development environment, repo layout, ADR đầu tiên

TUẦN
02**Core State & Orchestration**

- SQLite schema cho Context Store: tasks, artifacts, facts
- CLI cơ bản, task queue & scheduler skeleton
- Retry/resume, cost logging foundation
- Scope policy cơ bản, provenance tracking

TUẦN
03**Ingestion & Context Extraction**

- Git ingestion, snapshot / revision handling
- Route và symbol extraction (AST parser)
- Semgrep & Trivy adapters, SARIF normalizer
- Context retrieval theo route/symbol

TUẦN
04**Discovery Agents • Mid-point review**

- Recon agent, Fact extractor
- Specialist hunters (Lane A) + Tool signal ingestion (Lane B)
- Hypothesis Store + deduplication
- **Mid-point review với mentor & manager**

TUẦN
05**Independent Validation**

- Validator agent (độc lập với hunter)
- Evidence model, finding state machine implementation
- Validation plan, control/proof case framework
- Proof gap & validation wishlist

TUẦN
06**Developer Workflow**

- Finding report có repro / impact / evidence / remediation
- Developer feedback loop cơ bản, dismissal reasons
- Remediation guidance, fix verification procedure

TUẦN
07**Incremental Analysis & Evaluation**

- Change detection, stale propagation, impact analysis
- So sánh full scan vs incremental scan
- Đo precision, cost, runtime, cache hit

TUẦN
08**Hoàn thiện & Demo**

- Chạy benchmark cuối, hoàn thiện prototype
- Viết hướng dẫn sử dụng, chuẩn hoá report
- Chuẩn bị demo end-to-end với stakeholder
- Retrospective & đề xuất phase tiếp theo

10

Ngân sách & Nhân sự

10.1. Nhân sự

Vai trò	Số lượng	Trách nhiệm chính
Intern (Người thực hiện)	2	Xây dựng MVP, thí nghiệm, viết tài liệu — Vũ Văn Nam, Nguyễn Duy Phúc
Mentor kỹ thuật/security	1	Định hướng kỹ thuật, review PR, security review — [Chờ chỉ định]
Manager	1	Điều phối, review scope theo milestone — Nguyễn An Hưng

• Phân chia trách nhiệm dự kiến

Cả hai thành viên đều có nền tảng AI Agent và Security, do đó có thể cross-review cho nhau.

Vùng trách nhiệm	Chi tiết
Thành viên 1 — Core & Orchestration	CLI/Agent Skill, Scheduler, State store, Model provider interface, Cost tracking, Incremental update, Tool adapters
Thành viên 2 — Security Pipeline & Validation	Threat model, Fact/hypothesis/finding schema, Specialist hunters, Validation workflow, Evidence/reporting, Developer feedback, Benchmark
Trách nhiệm chung	Architecture review, Security review, Test, Documentation, Demo, Cross-validation kết quả

10.2. Công cụ & License

Công cụ	Loại	License / Ghi chú
Git	Source control	Open-source
SQLite	Persistent state	Public domain

Semgrep	SAST	OSS · Community edition
Trivy	SCA / CVE	Apache-2.0
OWASP ZAP	DAST (stretch goal)	Apache-2.0
Playwright	Runtime testing (stretch)	Apache-2.0
Codex / Claude Code / Kiro	Coding agent	Tùy điều kiện cấp phép

10.3. Ngân sách API AI

~\$20 KIRO / NGƯỜI	×2 THÀNH VIÊN	Free TOOLS (OSS)	~\$40 TỔNG ĐỀ XUẤT
--	-------------------------------------	--	--

💰 **Kiểm soát chi phí:** Cache theo content hash · Model rẻ cho fact extraction · Model mạnh chỉ dùng khi risk/uncertainty cao · Structured output · Context slicing · Deduplicate trước validation · Budget limit theo project và task · Theo dõi *cost per confirmed finding*.

⚠️ Nếu thử nghiệm mở rộng (multi-service, source nội bộ, hoặc external API premium), ngân sách API cần được báo cáo và phê duyệt riêng với Manager.

11

Rủi ro & Giảm thiểu

Rủi ro được đánh giá theo mức độ tác động lên khả năng hoàn thành MVP và chất lượng kết quả. Mỗi rủi ro có biện pháp giảm thiểu cụ thể được theo dõi trong review hàng tuần.

#	Rủi ro	Mức độ	Biện pháp giảm thiểu
1	Hallucination của AI — đưa ra finding sai/không có căn cứ	Cao	Independent validation + evidence-first + provenance bắt buộc + human review
2	Phạm vi quá lớn, không kịp deadline 8 tuần	Cao	Vertical slice MVP · Checkpoint tuần · Mid-point review T4 · Cắt bỏ tính năng non-critical
3	Rủi ro bảo mật khi xử lý dữ liệu nội bộ / secrets	Trung bình	Chỉ chạy trên repo open-source ở giai đoạn đầu · Không upload private code · Secret/PII redaction
4	Chi phí API vượt ngân sách	Trung bình	Budget guard · Tier 0 first · Cache aggressively · Structured output · Alert khi gần limit
5	Kết quả không tái hiện được (non-deterministic model output)	Trung bình	Snapshot input · Log seed/temperature · Evidence lưu trữ · Model & prompt version tracking
6	Thiếu runtime environment cho DAST	Trung bình	Đánh dấu VALIDATION_BLOCKED · Tạo validation wishlist · Ưu tiên whitebox trước
7	False positive gây mất niềm tin từ developer	Trung bình	Evidence threshold · Control/proof case · Feedback loop · Không confirmed nếu chưa đủ evidence
8	Dependency vào external tools (Semgrep, Trivy) breaking change	Thấp	Adapter abstraction · Pin version · Fallback rule
9	Mentor chưa được chỉ định	Thấp	Escalate với Manager sớm · Tự tổ chức peer review trong khi chờ
10	Remediation gây regression bug mới	Thấp	Minimal patch · Regression test bắt buộc · Fix verification chạy lại proof case

✓ **Nguyên tắc quản lý rủi ro:** Rủi ro được review hàng tuần trong buổi checkpoint. Nếu một rủi ro chuyển từ Trung bình → Cao, cần thảo luận với Manager để điều chỉnh phạm vi ngay.

12

Tiêu chí đánh giá

MVP được coi là hoàn thành khi thoả tối thiểu các tiêu chí kỹ thuật & quy trình dưới đây. Các stretch goal (runtime validation, ZAP, CI/CD sơ bộ) là điểm cộng, không phải điều kiện bắt buộc.

12.1. Tiêu chí kỹ thuật (bắt buộc)

- ☐ Cài đặt & chạy được bằng CLI hoặc Agent Skill
- ☐ MVP chạy end-to-end trên ít nhất 1 repository open-source thuộc stack đã chọn
- ☐ Persistent state với SQLite · Có resume & retry
- ☐ Tích hợp Semgrep & Trivy · Tool output được chuẩn hoá thành signal
- ☐ Ít nhất 2 specialist hunter hoạt động
- ☐ Discovery và Validation phân tách rõ ràng, độc lập
- ☐ Đầy đủ trạng thái Signal / Hypothesis / Confirmed / Rejected / Blocked
- ☐ Ít nhất 1 finding CONFIRMED có evidence đầy đủ (source location + control/proof case)
- ☐ Finding có provenance rõ ràng
- ☐ Report có repro steps · impact · remediation · fix verification procedure
- ☐ Có developer feedback cơ bản
- ☐ Đo được token · cost · latency · cache hit
- ☐ Incremental scan chạy nhanh hơn full scan (chứng minh bằng benchmark)
- ☐ Scope & approval policy hoạt động ở mức MVP

12.2. Tiêu chí quy trình

- ☐ Code có tests cơ bản, coverage tối thiểu cho core module
- ☐ Documentation: README · Architecture overview · Runbook
- ☐ Demo cuối kỳ với Manager & Mentor (end-to-end scan → fix verification)
- ☐ Retrospective & lessons learned document
- ☐ Handover materials sẵn sàng (nếu dự án tiếp tục ở phase sau)

- ☐ Đề xuất phase tiếp theo với priority rõ ràng

12.3. Metrics đánh giá chất lượng

Metric	Mục tiêu
Precision	Tỉ lệ finding CONFIRMED / tổng finding gửi developer — cần cải thiện so với raw scanner output
False positive rate	Giảm đáng kể so với chỉ dùng tool (Semgrep/Trivy)
Developer acceptance rate	Tỉ lệ finding được developer accept/fix / tổng finding
PoC reproduction success	Tỉ lệ finding CONFIRMED có PoC tái hiện được
Cost per confirmed finding	USD (hoặc token) chi cho mỗi finding được confirmed
Incremental savings	Thời gian & cost giảm khi chạy incremental so với full scan
Fix verification success	Tỉ lệ bản sửa được xác nhận (FIX_VERIFIED)

 **Metric chiến lược dài hạn:** "Chi phí và thời gian trên mỗi finding được developer chấp nhận và xử lý" — đây là chỉ số phản ánh chân thực nhất giá trị của SecWeave.



SecWeave

"Continuous · Contextual · Evidence-based Security Testing"

Cảm ơn đã dành thời gian xem xét đề xuất này.

Chúng tôi sẵn sàng thảo luận, điều chỉnh phạm vi và tiếp nhận góp ý từ Manager, Mentor và các bên liên quan để tối ưu hoá giá trị dự án.